

PyPI 与打包

本页与 `pypi.md` 配合使用：`pypi.md` 讲选型与概念地图，本页收术语对照、最小发布流程线索、镜像与安全，便于实验课或课后作业。

术语速查（课堂版）

名词	一句话
PyPI	Python 官方的 包索引 网站；用户通过 <code>pip</code> 等工具从这里（或镜像） 下载 已发布的发行版。
pip	从索引 安装包 到当前环境的命令行工具；不负责「替你写 <code>pyproject.toml</code> 」。
发行版 (distribution)	上传/下载的 制品 ，常见为 sdist （源码包）与 wheel （二进制/纯 Python 的预构建包）。
build 前端	如官方教程中的 <code>python -m build</code> ，按 <code>pyproject.toml</code> 调用后端 生成 <code>dist/</code> 下的制品。
setuptools / flit / hatch...	构建后端 或项目工具链的一部分；新课以 <code>pyproject.toml</code> 为中心配置，而非手写长篇 <code>setup.py</code> 。

最小发布练习（建议用 TestPyPI）

- 在 [TestPyPI](#) 注册账号（练习环境，与正式 PyPI 隔离）。
- 本地准备一个**最小可安装项目**（含 `pyproject.toml`），按官方教程 [打包 Python 项目](#) 构建。
- 使用 **API token**（账户设置里创建）配合 `twine upload --repository testpypi dist/*`，**不要把 token 写进仓库**。
- 用 `pip install -i https://test.pypi.org/simple/ ...` 验证能否从 TestPyPI 安装自己的包。

正式上传 PyPI 前，务必再读一遍 [发布检查清单](#) 与项目许可证是否已声明。

国内课堂环境：镜像

校园网访问 PyPI 较慢时，可临时使用国内镜像（以所在学校/实验室文档为准），例如清华大学开源镜像站说明页：

<https://mirrors.tuna.tsinghua.edu.cn/help/pypi/>

提醒学生：镜像只解决下载，上传发布仍须对接官方或教师提供的索引说明。

安全与供应链

- 令牌：API token 当作密码；用环境变量或 CI 密钥注入，勿提交到 Git。
 - 抢注与依赖混淆：包名与依赖声明尽量固定版本或哈希；勿盲目 `pip install` 陌生名字的包。
 - 与「开源软件安全」章：可结合 SBOM、依赖扫描等主题布置读书报告。
-

延伸阅读

- 官方总览（与 `pypi.md` 同源）：https://packaging.python.org/zh_CN/latest/overview.html
- 中文文档首页：https://packaging.python.org/zh_CN/latest/